

The Future of India's Digital Security Framework

Strengthening data protection under the Information Technology Act, the DPDP Act and Rules, intermediary regulation, and global security standards.

LEGAL UPDATE

DPDP Rules, 2025: phased implementation and a digital-first Data Protection Board.

2026 FOCUS

Deepfakes and synthetically generated information under the amended IT Rules.

PRACTICE TOOL

A 90-day organisational readiness roadmap for data governance and cyber resilience.



EDITOR'S BRIEF

Law, technology and trust must move together.

India's digital transformation has moved beyond the question of access. The central issue is now whether data-intensive growth can remain secure, accountable and rights-respecting at national scale.

This edition consolidates the legal architecture across the Information Technology Act, 2000, the IT Rules, 2021 as amended, CERT-In's incident-response directions, and the Digital Personal Data Protection Act, 2023 with the final DPDP Rules, 2025. It also connects legal compliance with operational frameworks such as the GDPR, NIST Cybersecurity Framework 2.0 and ISO/IEC 27001:2022.

Editorial correction to the submitted manuscript: the DPDP Rules are no longer "forthcoming". They were notified in November 2025, with Board-related provisions commencing immediately and the main compliance framework being phased over eighteen months.^[3]

Legal position verified up to 24 July 2026. This publication provides a general legal and policy overview, not advice on a specific matter.

IN THIS ISSUE

01 Digital India at Scale Why the security question is now systemic

02 India's Legal Architecture Constitution, statutes, rules and directions

03 DPDP Operating Model Principles, roles, scope and rights

04 Rules & Breach Response Phased commencement and compliance lifecycle

05 Cyber Offences Key provisions under the IT Act

06 Intermediaries & Deepfakes The 2026 SGI compliance shift

07 Global Alignment GDPR, NIST CSF and ISO/IEC 27001

08 90-Day Readiness Plan Governance, controls and evidence

"Digital trust is not created by a privacy notice alone. It is created by lawful purpose, restrained collection, secure systems, accountable vendors and credible incident response."

01 / DIGITAL INDIA AT SCALE

A billion-scale data economy changes the risk equation.

Connectivity, digital public infrastructure, payments, cloud adoption and AI have made personal-data governance a board-level issue rather than a narrow technology function.

1.09B

Internet subscriptions in India as of March 2026. This is a subscription count, not a count of unique individuals.

TRAI dashboard^[1]

1.07B

Broadband subscriptions as of March 2026, demonstrating the scale at which online services process identity and behavioural data.

TRAI dashboard^[1]

~20%

Projected contribution of India's digital economy to national income by 2030 - nearly one-fifth, according to a government report.

PIB / MeitY report^[2]

Why risk is compounding

Every digital interaction can create a chain of identifiers, transaction data, location information, device signals, communications, preferences and inferred attributes. The security perimeter now extends across employees, cloud infrastructure, software vendors, payment partners, analytics services and AI models.

Cyber incidents are therefore rarely only "IT incidents". They can simultaneously trigger contractual liability, regulatory reporting, consumer claims, criminal investigation, operational disruption and reputational loss.

Legal consequence: organisations need a unified control environment in which privacy, cybersecurity, records management, procurement and incident response share the same data inventory and accountability map.

Threat convergence

Identity: credential theft, SIM-swap, impersonation, deepfakes.

Availability: ransomware, denial-of-service, destructive attacks.

Confidentiality: exfiltration, exposed cloud storage, insider misuse.

Integrity: altered records, synthetic media, poisoned datasets.

Financial harm: phishing, payment fraud, account takeover.

The strategic shift: India's framework increasingly treats cybersecurity, personal-data protection and platform accountability as interconnected layers of digital governance.

02 / LEGAL ARCHITECTURE

India's digital-security framework is layered, not contained in one statute.

The governing obligations depend on what happened, who processed the data, the role of the platform, the sector involved, and whether the event is a cyber incident, personal-data breach, unlawful-content issue or criminal offence.

01	Constitutional foundation Justice K.S. Puttaswamy (Retd.) v. Union of India recognised privacy as a fundamental right, framing legality, legitimate aim and proportionality as central constitutional concerns.	RIGHTS & STATE ACTION
02	Information Technology Act, 2000 Electronic governance, cyber contraventions and offences, confidentiality, protected systems, CERT-In powers and intermediary safe harbour.	CYBER LAW
03	IT Rules, 2021 - as amended Due diligence, grievance redressal, compliance officers, content-removal obligations, traceability in specified cases, and 2026 duties for synthetically generated information.	PLATFORM GOVERNANCE
04	DPDP Act, 2023 + DPDP Rules, 2025 Lawful processing of digital personal data, rights of Data Principals, duties of Data Fiduciaries, breach response, children's data, Significant Data Fiduciaries and Board enforcement.	DATA PROTECTION
05	CERT-In directions and sectoral regulation Cyber-incident reporting, log retention and operational directions; supplemented by RBI, SEBI, IRDAI, DoT and other sector-specific cybersecurity and outsourcing requirements.	INCIDENT & SECTOR CONTROLS
Regulatory overlap is normal A ransomware event affecting customer records may require CERT-In reporting, DPDP breach notification when the relevant provisions commence, contractual notices to clients, sectoral reporting, preservation of evidence and a criminal complaint. Classification comes first Before acting, classify the event: personal-data breach, cyber incident, unlawful content, financial fraud, service outage, insider misconduct or a combination. Reporting clocks and responsible teams should follow that classification.		
Drafting point: contracts should not use "data breach", "security incident" and "cyber incident" as interchangeable terms. Define each term, align notification timelines and preserve the stricter statutory duty.		

03 / DPDP OPERATING MODEL

The DPDP framework regulates the full data lifecycle.

The Act applies to digital personal data processed in India, including data first collected offline and later digitised, and to processing outside India connected with offering goods or services to Data Principals in India.^[4]

Consent & transparency

Consent must be free, specific, informed, unconditional and unambiguous, unless a specified legitimate use applies.

Purpose limitation

Process data for lawful, specified purposes communicated to the individual.

Data minimisation

Collect and use only data reasonably connected with the stated purpose.

Accuracy

Take reasonable steps where data is used to make decisions or disclosed to another fiduciary.

Storage limitation

Erase data when consent is withdrawn or purpose is no longer served, subject to legal retention.

Security safeguards

Protect personal data through reasonable technical and organisational measures.

Accountability

The Data Fiduciary remains responsible even where processing is performed by a processor.

Individual rights

Access information, correction, updating, erasure, grievance redressal and nomination.

Data Principal

The individual to whom the personal data relates; guardian arrangements apply in specified cases.

Data Fiduciary

Determines the purpose and means of processing, alone or with others.

Data Processor

Processes personal data on behalf of the Data Fiduciary under a valid contract.

Consent Manager

A Board-registered entity enabling consent to be given, managed, reviewed or withdrawn.

Not consent-only

The Act permits processing on consent and on specified "certain legitimate uses". Compliance design must identify the precise statutory ground for each processing purpose rather than placing every activity under a generic consent clause.

Cross-border transfers

The model is generally permissive: personal data may be processed outside India, except to countries or territories restricted by Central Government notification and subject to stricter sectoral requirements.

Penalty exposure: the Schedule permits penalties up to ₹250 crore for failure to take reasonable security safeguards, with separate upper limits for breach notification and children's-data violations.^[3]

Source: Gazette notification, rule 1.^[5]

Purposes,
systems,
datasets,
vendors
and
transfer
locations.

Standalone,
clear notice
with
itemised
data and
purposes.

Consent or specified legitimate use;
maintain evidence.

Encryption,
masking,
access
controls,
logs,
backups
and
contracts

Purpose-based retention, legal holds and documented erasure.

Communicate breach nature, likely consequences, mitigation, protective steps and a contact point in clear language.

Initial intimation is without delay;
detailed information follows within 72
hours unless the Board permits more
time.

The final Rules expressly identify encryption or masking, access controls, logging and monitoring, backups, one-year retention of specified logs and data, processor-contract safeguards, and technical and organisational measures.^[5]

Obtain verifiable parental consent, subject to specified exemptions and prescribed verification methods.

Publish a DPO or responsible person's business contact for data-processing questions and rights requests.

Document channels, identity verification, response ownership, grievance escalation and evidence of closure.

05 / INFORMATION TECHNOLOGY ACT, 2000

The IT Act remains the principal cyber-offence and electronic-governance statute.

The DPDP framework does not replace criminal and contravention provisions dealing with unauthorised access, identity theft, impersonation, privacy violations and unlawful electronic content.

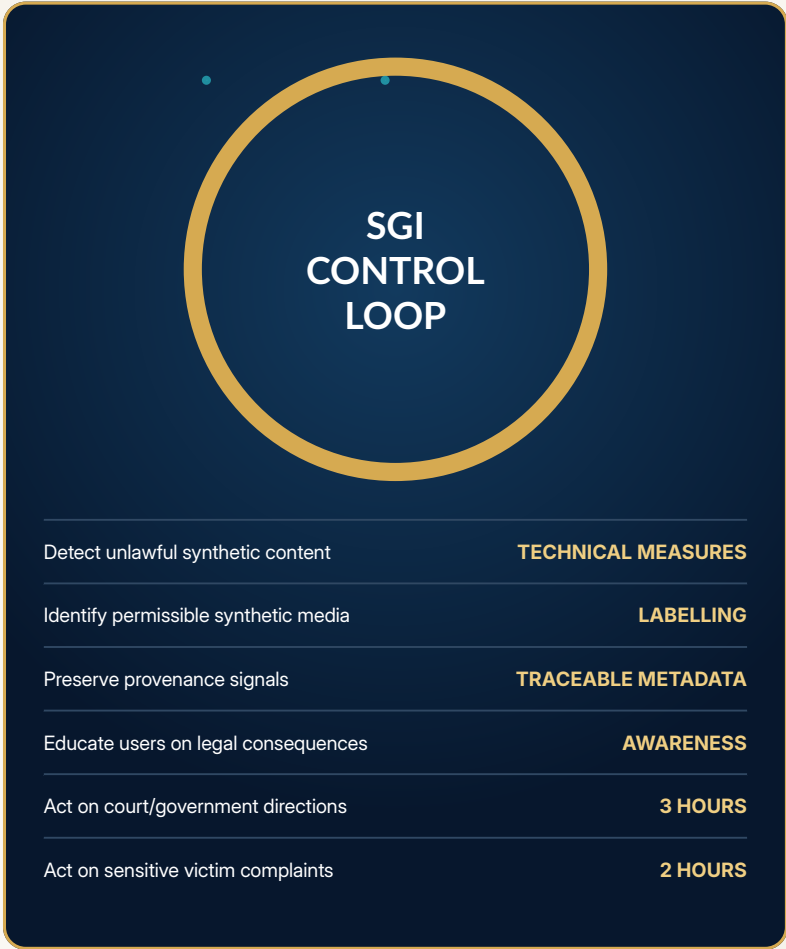
Provision	Core subject	Practical relevance
Section 43	Unauthorised access, downloading, introduction of contaminants, disruption, denial of access and damage to computer resources.	Supports civil compensation for specified unauthorised acts; often relevant to insider misuse and system intrusion.
Section 66	Computer-related offences where Section 43 acts are committed dishonestly or fraudulently.	Converts specified conduct into a criminal offence when the statutory mental element is present.
Section 66C	Identity theft involving fraudulent or dishonest use of electronic signatures, passwords or unique identification features.	Credential misuse, account takeover and stolen authentication data.
Section 66D	Cheating by personation through a communication device or computer resource.	Phishing, fake support calls, fraudulent profiles and online financial deception.
Section 66E	Violation of privacy through capturing, publishing or transmitting images of a private area without consent.	Technology-facilitated privacy abuse and non-consensual imagery.
Sections 67-67B	Obscene, sexually explicit and child sexual abuse material in electronic form.	Content offences, platform takedown and law-enforcement cooperation.
Section 70B	CERT-In as the national incident-response agency and power to issue directions.	Incident reporting, information requests, cybersecurity practices and response coordination.
Section 72	Breach of confidentiality and privacy by a person who secured access under statutory powers.	Protects information obtained through legally conferred access.
Section 72A	Disclosure of personal information in breach of lawful contract, with intent or knowledge of likely wrongful loss or gain.	Contract-linked confidentiality misuse; requires attention to its specific ingredients.
Section 79	Conditional safe harbour for intermediaries for third-party information, data or communication links.	Protection depends on observing due diligence and acting on legally valid knowledge or directions.

Investigation point: preserve logs, access records, email headers, transaction trails, device information, contractual permissions and chain of custody. A data-protection assessment does not substitute for criminal evidence preservation.

Pleading point: identify the exact act, system, access route, loss, intent and statutory ingredients. Avoid describing every cyber dispute merely as “hacking”.

2026 brought deepfakes and AI-generated content into sharper regulatory focus.

The amended IT Rules define and regulate synthetically generated information (SGI), strengthen platform due diligence, and shorten key response timelines.^[7]



Who is affected?

Intermediaries and social-media platforms to the extent covered by the IT Act and Rules. Significant Social Media Intermediaries carry additional officer, reporting and technical obligations.

What changed?

Platforms must deploy reasonable and appropriate measures against unlawful SGI, while permissible synthetic content requires clear labelling and traceable metadata to reduce deception and impersonation risks.

Safe harbour is conditional

Failure to observe due diligence may result in loss of Section 79 protection, exposing the intermediary to consequences under applicable law.

Grievance design

Provide accessible reporting channels, trained reviewers, escalation rules and reasoned closure records.

Victim-centred action

Prioritise impersonation, non-consensual intimate imagery, child harm and privacy-invasive synthetic content.

Evidence discipline

Preserve hashes, URLs, timestamps, account identifiers and decision logs without unnecessarily retaining harmful content.

07 / GLOBAL STANDARDS

Global alignment should be functional, not cosmetic.

The GDPR is a useful legal comparator, while NIST CSF 2.0 and ISO/IEC 27001:2022 provide operational structures for managing security risk. They are not substitutes for Indian law.

ISSUE	INDIA - DPDP FRAMEWORK	EU - GDPR
Scope	Digital personal data; extraterritorial reach linked to offering goods or services to Data Principals in India.	Personal data processing; extraterritorial reach includes offering goods/services and monitoring behaviour in the Union.
Legal grounds	Consent and specified legitimate uses under the Act.	Multiple lawful bases, including consent, contract, legal obligation, vital interests, public task and legitimate interests.
Individual rights	Access information, correction, updating, erasure, grievance redressal and nomination.	Broader suite including access, rectification, erasure, restriction, portability, objection and safeguards against certain automated decisions.
Regulator	Data Protection Board of India; digital-first adjudicatory model; appeals to TDSAT.	Independent national supervisory authorities and European coordination mechanisms.
Transfers	Generally allowed except restricted jurisdictions, subject to sectoral law.	Adequacy, safeguards, derogations and detailed transfer jurisprudence.
Penalties	Fixed statutory upper limits by category, including up to ₹250 crore.	Tiered administrative fines linked to turnover or fixed amounts, whichever is higher.

GDPR

Use as a comparative legal benchmark for transparency, accountability, processor contracts, impact assessments and cross-border governance.^[8]

NIST CSF 2.0

Organises cybersecurity outcomes through Govern, Identify, Protect, Detect, Respond and Recover - useful for linking legal duties to enterprise risk management.^[9]

ISO/IEC 27001:2022

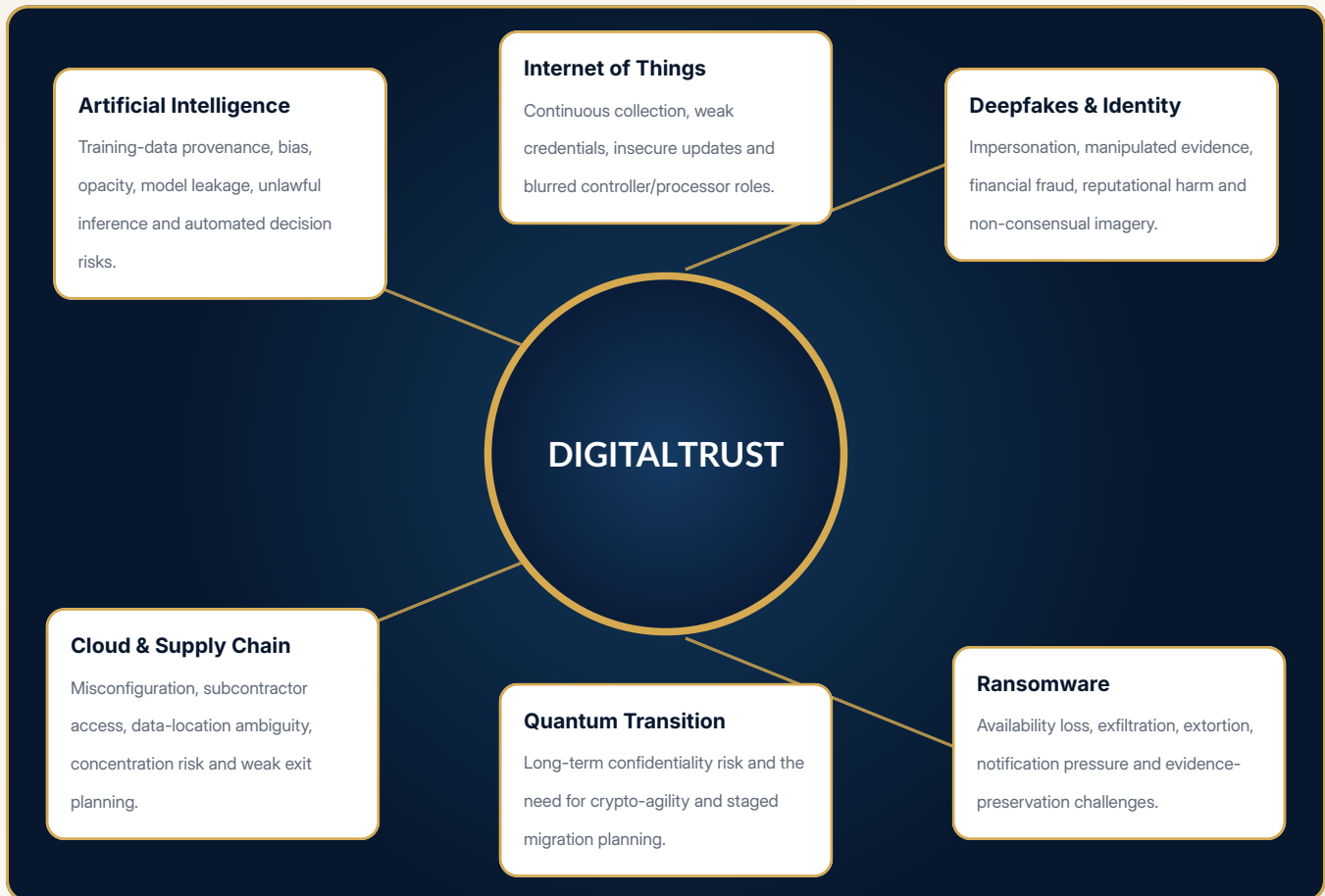
Provides auditable requirements for an information security management system based on risk assessment, controls and continual improvement.^[10]

Best practice: build one evidence framework that maps each control to Indian legal duties, contractual commitments, sectoral requirements and chosen global standards.

EMERGING RISK MAP

New technologies amplify old legal questions.

The most durable response is technology-neutral governance: clear purpose, accountable ownership, traceable decisions, proportionate safeguards and tested incident response.



Privacy by design

Embed purpose, minimisation, retention, user rights and security requirements before product launch.

Security by default

Least privilege, MFA, encryption, secure configuration, monitoring, backups and vulnerability management.

Accountability by evidence

Approvals, data maps, test results, contracts, incident logs, training records and audit trails.

08 / PRACTICE TOOL

A 90-day readiness roadmap for organisations.

The implementation window should be used to create demonstrable, repeatable and tested compliance - not merely to redraft a privacy policy.

0-30 DISCOVER & GOVERN	31-60 DESIGN & REMEDIATE	61-90 TEST & EVIDENCE
● Appoint an executive owner and cross-functional working group. ● Map personal-data purposes, systems, categories, sources and recipients. ● Identify processors, sub-processors, cloud locations and cross-border flows. ● Classify legal grounds: consent, legitimate use, contract or statutory obligation. ● Create an incident-classification and notification matrix. ● Freeze high-risk collection that has no documented purpose or owner.	● Redraft notices into clear, standalone and purpose-specific language. ● Build consent capture, withdrawal and evidence mechanisms. ● Implement rights-request and grievance workflows with defined service levels. ● Update processor agreements, audit rights, breach clauses and deletion duties. ● Apply encryption, masking, access controls, logging, backups and retention rules. ● Design parental-consent processes where children's data is processed.	● Conduct a tabletop breach exercise involving legal, security, communications and management. ● Test restoration, account revocation, regulator notification and customer messaging. ● Review high-risk AI, profiling, biometric and large-scale datasets. ● Train employees and specialised teams using scenario-based exercises. ● Complete an internal audit and obtain management sign-off on residual risks. ● Create a quarterly review cycle and board-level dashboard.

MINIMUM EVIDENCE PACK

✓ Approved data inventory and processing-purpose register	✓ Vendor and sub-processor register with contract status
✓ Notice, consent and rights-request records	✓ Security-control test results and remediation evidence
✓ Incident-response plan and tabletop exercise report	✓ Retention schedule, deletion proof and legal-hold process
✓ Training completion and role-based awareness records	✓ Management review, risk acceptance and audit trail

THE ROAD AHEAD

India can become not only a large digital economy, but a trusted one.

The next phase of digital governance will be determined by enforcement quality, institutional capacity, interoperable standards and the willingness of organisations to treat data protection as a continuing management system.

As artificial intelligence, connected devices, decentralised finance and post-quantum security reshape the risk landscape, law must remain technologically informed without becoming technology-bound. The strongest framework will combine constitutional rights, statutory accountability, operational resilience and international cooperation.

Juris Insight perspective: compliance is mature when an organisation can explain what data it holds, why it holds it, who can access it, how long it is retained, how it is protected, and what happens when the system fails.

OFFICIAL AND PRIMARY REFERENCES - CLICKABLE

[1] Telecom Regulatory Authority of India. March 2026 dashboard figures for internet and broadband subscriptions. [Open official source.](#)

[2] Press Information Bureau / MeitY. Report projection that India's digital economy may contribute nearly one-fifth of national income by 2030. [Open official source.](#)

[3] Press Information Bureau. "DPDP Rules, 2025 Notified - A Citizen-Centric Framework for Privacy Protection and Responsible Data Use", 17 November 2025. [Open official source.](#)

[4] India Code. Digital Personal Data Protection Act, 2023, Act No. 22 of 2023. [Open official source.](#)

[5] Ministry of Electronics and Information Technology. Digital Personal Data Protection Rules, 2025, Gazette Notification G.S.R. 846(E), including phased commencement, safeguards and breach notification. [Open official Gazette PDF.](#)

[6] CERT-In. Directions under Section 70B of the Information Technology Act, 2000 relating to information security practices and cyber-incident reporting, dated 28 April 2022. [Open official source.](#)

[7] Ministry of Electronics & IT / PIB. 2026 amendments to the IT Rules addressing synthetically generated information, deepfakes, labelling, metadata and shortened action timelines. [Open official source.](#)

[8] European Union. Regulation (EU) 2016/679 - General Data Protection Regulation. [Open EUR-Lex.](#)

[9] National Institute of Standards and Technology. NIST Cybersecurity Framework 2.0. [Open NIST.](#)

[10] International Organization for Standardization. ISO/IEC 27001:2022 - Information security management systems - Requirements. [Open ISO.](#)

Author's Note & Disclaimer. This newsletter is intended for educational and informational purposes and provides a general overview of India's evolving digital-security and data-protection framework. It does not constitute legal advice, a legal opinion, or a substitute for advice based on the facts of a specific matter. Statutory provisions, commencement notifications, rules and directions should be checked in their official form before reliance. AI-assisted legal content has been reviewed and structured for publication by Juris Insight.